

§ 170.315(g)(10)

Standardized API for patient and population services

Certification Companion Guide v1.12

Issued Date: 03-11-2024

Last Updated: 05-15-2026

This Certification Companion Guide (CCG) is an informative document designed to assist with health IT product certification. The CCG is not a substitute for the requirements outlined in regulation and related ONC final rules. It extracts key portions of ONC final rules' preambles and includes subsequent clarifying interpretations. To access the full context of regulatory intent please consult the [Certification Regulations](#) page for links to all ONC final rules or consult other regulatory references as noted. The CCG is for public use and should not be sold or redistributed.

Certification Clarifications

Technical Explanations and Clarifications

Applies to all applicable base regulatory and SVAP standards:

- Health IT Modules are not required to support patient-facing API-enabled “read” services for multiple patients for the purposes of this certification criterion.
- The clinical note text included in any of the notes described in the “Clinical Notes Guidance” section of a US Core Implementation Guide (IG) adopted in § 170.215(b)(1) must be represented in a “plain text” form, and it would be unacceptable for the note text to be converted to another file or format (e.g., .docx, PDF) when it is provided as part of an API response. The intent of this policy is to prohibit Health IT Modules from converting clinical notes from a “machine readable” format to a non-“machine readable” format (e.g., PDF). Clinical note text that originates from outside Health IT Modules should be exchanged using its original format. Additionally, “plain text” does not necessarily mean the FHIR® “contentType” “text/plain.”
- The US Core IG Profile “StructureDefinition-us-core-patient” element “name.suffix” is required for testing and certification in the Certification Program to meet the USCDI requirement to support the “Patient Demographics” Data Class: “Suffix” Data Element.

- A Health IT Module must support at least one Choice or Reference for US Core IG “must support” elements with multiple Choices or References, respectively.
- A Health IT Module must be conformant to the US Core IG for all Choices and References included in its standardized API, and cannot misrepresent Choices via the standardized API (e.g. a Health IT Module cannot transform “integer” values to “string” values).
- A health IT developer must document which US Core IG Choices and References are supported by their Health IT Module via public technical documentation to meet the requirements at § 170.315(g)(10)(viii) and the transparency conditions at § 170.404(a)(2).
- Information originating from the (g)(10)-certified Health IT Module must conform to the requirements included in the criterion, but legacy information and information from outside systems is not required to be mapped to the USCDI “Applicable Standards” and the US Core IG terminologies and value sets. However, health IT developers are encouraged to exceed the minimum requirements described in § 170.315(g)(10) to support the mapping of legacy information to the terminologies and value sets included in the USCDI and US Core IG where possible.
- In order to mitigate potential interoperability errors and inconsistent implementation of the Fast Healthcare Interoperability Resources (FHIR®) Bulk Data Access (Flat FHIR®) (v1.0.0: STU 1) standard, ONC assesses, approves, and incorporates corrections (errata) as part of required certification and testing to this criterion. Compliance with the following errata is necessary because the errata implements technical corrections and clarifications to the FHIR® Bulk Data Access (Flat FHIR®) (v1.0.0: STU 1) standard. There is a 90-day delay from the time the CCG has been updated with the ONC-approved errata to when compliance with the errata will be required to pass testing. Similarly, there will be an 18-month delay before a finding of an erratum’s absence in a Certified Health IT Module during surveillance would constitute a non-conformity under the Certification Program.
 - Version: [FHIR® Bulk Data Access \(Flat FHIR®\) \(v1.0.1: STU 1\)](#). Effective for testing on October 25, 2021. Surveillance compliance date on January 27, 2023.
- In order to mitigate potential interoperability errors and inconsistent implementation of the HL7® FHIR® US Core Implementation Guide STU 8.0.0, ONC assesses, approves, and incorporates corrections (errata) as part of required certification and testing to this criterion. Compliance with the following errata is necessary because the errata implements technical corrections and clarifications to the HL7® FHIR® US Core Implementation Guide STU 8.0.0. There is a 90-day delay from the time the CCG has been updated with the ONC-approved errata to when compliance with the errata will be required to pass testing. Similarly, there will be an 18-month delay before a finding of an erratum’s absence in a Certified Health IT Module during surveillance would constitute a non-conformity under the Certification Program.
 - Version: [HL7® FHIR® US Core Implementation Guide STU 8.0.1](#). Effective for testing on August 13, 2026. Surveillance compliance date on November 15, 2027.
- Through the [US Core Patch Process](#), the HL7® Cross-Group Projects Work Group (CGP WG) approves US Core “patches”, which are corrections for issues with the US Core implementation guide (US Core IG). US Core “patches” include corrections for issues such as ambiguous requirements and requirements incompatible with real world deployment. Similar to US Core “patches” are US Core “additional guidance”. US Core “additional guidance” approved by the CGP WG indicates guidance included in a newer version of the US Core IG as being relevant to a previous version of the US Core IG. Though US Core “patches” and “additional guidance” are not required for certification purposes (unless indicated in the Certification Companion Guide), health IT developers may optionally

implement US Core “additional guidance” in their Health IT Module and still be conformant with § 170.315(g)(10) criterion requirements.

- More information regarding the US Core Patch Process and US Core “patches” and “additional guidance” approved by the CGP WG is available on the HL7[®] Confluence pages of [US Core 'Patch' Process](#) and [Approved Patches and Additional Guidance](#).
- Consistent with Executive Order (EO) 14168 and OPM guidance, Health IT Modules certifying and/or currently certified to certification criteria that cross-reference the USCDI standard at 45 CFR 170.213 are only required to demonstrate the capability to categorize data on individuals for the sex data element in accordance with the following SNOMED CT[®] codes:
 - 248152002 |Female (finding)| and
 - 248153007 |Male (finding)|
- Further, these Health IT Modules are no longer required to support the following USCDI data elements for purposes of certification:
 - Sexual orientation in USCDI version 4;
 - Gender identity in USCDI version 4;
 - Sex parameter for clinical use in USCDI version 5;
 - Name to use in USCDI version 5;
 - Pronouns in USCDI version 5.

Technical outcome – Respond to requests for a single patient’s data according to the standards and implementation specifications adopted in § 170.215(a) and (b)(1), including the mandatory capabilities described in “US Core Server CapabilityStatement,” for each of the data included in the corresponding standard adopted in § 170.213. All data elements indicated as “mandatory” and “must support” by the standards and implementation specifications must be supported.

Applies to all applicable base regulatory and SVAP standards:

- All data elements and operations indicated as “mandatory” and “must support” by the standards and implementation specifications must be supported and are in-scope for testing.
- Health IT Modules must support provenance according to the [“Basic Provenance Guidance” section of the US Core IG](#).
- For purposes of ONC Health IT Certification, health IT developers that always provide HL7[®] FHIR[®] “observation” values are not required to demonstrate Health IT Module support for “dataAbsentReason” elements. These include “dataAbsentReason” elements contained in the US Core implementation guide profiles and FHIR[®] Vital Sign profiles that build on the HL7[®] FHIR[®] “observation” and its derived profiles including HL7[®] FHIR[®] “observation-vitalsigns”, and HL7[®] FHIR[®] “observation-oxygen-sat”, including “component.dataAbsentReason” elements. However, health IT developers are

still required to adhere to and demonstrate Health IT Module support for the [“Missing Data” section](#) of the US Core implementation guide.

- For purposes of testing and certification, health IT developers are not required to demonstrate Health IT Module support for the “USCoreFetchDocumentReferences” (\$docref) US Core IG operation.

Applies to USCDI v3 and US Core 6.1.0:

- The HL7® Cross-Group Projects workgroup approved the [US Core 'Patch' Process](#) ticket [FHIR-45319](#) for US Core 6.1.0. In alignment with that issued guidance, the Health IT Module must support all four codes from the US Core Screening Assessment Observation Category ValueSet for the US Core Observation Screening Assessment Profile for “Observation.category:screening-assessment”. Additionally, the Health IT Module must support the “sdoh” code from the US Core Screening Assessment Condition Category ValueSet for the US Core Condition Problems and Health Concerns Profile for “Condition.category:screening-assessment”.
- For the “Organization” and “Practitioner” US Core IG profile, only the “read” type interaction must be supported and will be included in testing and certification. For the “Location” FHIR® resource, Health IT Modules must either demonstrate support for the “read” type interaction or demonstrate support for providing the “Location” FHIR® resource reference as a contained resource. The “search” type interactions for these profiles and resource are not in scope for testing and certification. Health IT Modules must support these US Core IG profiles / FHIR® resource because they are included as “must support” data elements in US Core IG profiles required by the United States Core Data for Interoperability (USCDI).
- For purposes of testing and certification, health IT developers are not required to demonstrate Health IT Module support for the “QuestionnaireResponse” US Core IG profile.
- The HL7® Cross-Group Projects workgroup, through the [US Core 'Patch' Process](#) ticket [FHIR-43355](#), approved patching the US Core Smoking Status Observation Profile in US Core 6.1.0. For purposes of certification, the clinically relevant time/time-period for observation for the US Core Smoking Status Observation Profile may be supported using either Observation.effectiveDateTime or Observation.effectivePeriod data elements, where Observation.effectivePeriod has the [“Period”](#) type.
- The HL7® Cross-Group Projects workgroup, through the [US Core 'Patch' Process](#) ticket [FHIR-44693](#), approved patching the US Core Practitioner Profile in US Core 6.1.0. For purposes of certification, Practitioner.address from the US Core Practitioner Profile is not required to be supported if the Health IT Module supports the US Core PractitionerRole Profile.
- The HL7® Cross-Group Projects workgroup, through the [US Core 'Patch' Process](#) ticket [FHIR-46240](#), approved patching the US Core DiagnosticReport Profile for Report and Note Exchange in US Core 6.1.0. For purposes of certification, DiagnosticReport.media and DiagnosticReport.media.link from the US Core DiagnosticReport Profile for Report and Note Exchange are not required to be supported.
- The HL7® Cross-Group Projects workgroup, through the [US Core 'Patch' Process](#) ticket [FHIR-50283](#), approved patching the US Core Coverage Profile in US Core 6.1.0. For purposes of certification for the US Core Coverage
 - Coverage.class:group.name is not required to be supported
 - Coverage.class:group.value should represent “Group Identifier”
- The HL7® Cross-Group Projects workgroup, through the [US Core 'Patch' Process](#) ticket [FHIR-50239](#), approved patching the US Core MedicationDispense Profile in US Core 6.1.0. For purposes of

certification, references to US Core Practitioner Profile are not required to be supported for the MedicationDispense.performer.actor for the US Core MedicationDispense Profile.

- The HL7® Cross-Group Projects workgroup, through the [US Core 'Patch' Process](#) ticket [FHIR-50288](#), approved patching the US Core Condition Encounter Diagnosis Profile in US Core 6.1.0. For purposes of certification, Condition.extension:assertedDate, Condition.onset[x], Condition.abatement[x], Condition.clinicalStatus, and Condition verificationStatus from the US Core Condition Encounter Diagnosis Profile are not required to be supported.

Applies to SVAP approved standards USCDI v4 and US Core 7.0.0:

- For the “Organization” and “Practitioner” US Core IG profiles, only the “read” type interaction must be supported and will be included in testing and certification. The “search” type interactions for these profiles are not in scope for testing and certification. Health IT Modules must support these US Core IG profiles because they are included as “must support” data elements in US Core IG profiles required by the United States Core Data for Interoperability (USCDI).
- For purposes of testing and certification, health IT developers are not required to demonstrate Health IT Module support for the “QuestionnaireResponse” US Core IG profile.
- The HL7® Cross-Group Projects workgroup, through the [US Core 'Patch' Process](#) ticket [FHIR-50283](#), approved patching the US Core Coverage Profile in US Core 7.0.0. For purposes of certification for the US Core Coverage Profile:
 - Coverage.class:group.name is not required to be supported
 - Coverage.class:group.value should represent “Group Identifier”
- The HL7® Cross-Group Projects workgroup, through the [US Core 'Patch' Process](#) ticket [FHIR-50239](#), approved patching the US Core MedicationDispense Profile in US Core 7.0.0. For purposes of certification, references to US Core Practitioner Profile are not required to be supported for the MedicationDispense.performer.actor for the US Core MedicationDispense Profile.
- The HL7® Cross-Group Projects workgroup, through the [US Core 'Patch' Process](#) ticket [FHIR-50288](#), approved patching the US Core Condition Encounter Diagnosis Profile in US Core 7.0.0. For purposes of certification, Condition.extension:assertedDate, Condition.onset[x], Condition.abatement[x], Condition.clinicalStatus, and Condition verificationStatus from the US Core Condition Encounter Diagnosis Profile are not required to be supported.

Applies to SVAP approved standards USCDI v5 and US Core 8.0.1:

- For the “Organization” and “Practitioner” US Core IG profiles, only the “read” type interaction must be supported and will be included in testing and certification. The “search” type interactions for these profiles are not in scope for testing and certification. Health IT Modules must support these US Core IG profiles because they are included as “must support” data elements in US Core IG profiles required by the United States Core Data for Interoperability (USCDI).
- For purposes of testing and certification, health IT developers are not required to demonstrate Health IT Module support for the [“QuestionnaireResponse” US Core IG profile](#).

Technical outcome – Respond to requests for multiple patients’ data as a group according to the standards and implementation specifications adopted in § 170.215(a), (b)(1) and (d), for each of the data included in the corresponding standard adopted in § 170.213. All data elements indicated as “mandatory” and “must support” by the standards and implementation specifications must be supported.

Applies to all applicable base regulatory and SVAP standards:

- Health IT Modules may support scopes using either the system wildcard scope syntax or a list of - system resource scopes- to enable the export of multiple patients’ data as a group.
- During testing and certification for multiple patient services, Health IT Modules must demonstrate support for “Encounter,” “Organization,” and “Practitioner” US Core IG FHIR® Profiles.
- Health IT Modules must support provenance according to the “Basic Provenance Guidance” section of the US Core IG.

Applies to USCDI v3 and US Core 6.1.0:

- Health IT Modules must demonstrate support for the “Location” FHIR® resource by either providing this resource as part of the multiple patient services response, or by including it as a contained resource as part of the multiple patient services response.

Technical outcome – Respond to search requests for a single patient’s data consistent with the search criteria included in the implementation specification adopted in § 170.215(b)(1), specifically the mandatory capabilities described in “US Core Server CapabilityStatement”.

Applies to all applicable base regulatory and SVAP standards:

- All data elements indicated as “mandatory” and “must support” by the standards and implementation specifications must be supported and are in scope for testing.
- The § 170.315(g)(10) certification criterion requires Health IT Modules to support API-enabled “read” services for single and multiple patients. “Read” services include those that allow authenticated and authorized third-party applications to view EHI through a secure API. These services specifically exclude “write” capabilities, where authenticated and authorized third-party applications would be able to create or modify EHI through a secure API.

Technical outcome – Respond to search requests for multiple patients' data consistent with the search criteria included in an implementation specification adopted in § 170.215(d).

Applies to all applicable base regulatory and SVAP standards:

- No additional clarifications.

Technical outcome – Enable an application to register with the Health IT Module's “authorization server.”

Applies to all applicable base regulatory and SVAP standards:

- Health IT presented for testing and certification must support app registration regardless of the scope of patient search utilized by the application (e.g., single or multiple).
- This certification criterion requires a health IT developer, as finalized in the Condition of Certification requirements, to demonstrate its registration process, but does not require conformance to a standard.
- The third-party application registration process that a health IT developer must meet under this criterion is not a form of review or “vetting” for purposes of this criterion.

Applies to USCDI v3 and US Core 6.1.0:

- For demonstration of the SMART IG “Standalone Launch” steps, health IT developers are permitted to scope US Core IG resources that do not exist in either the standard adopted at § 170.213(b) (USCDI v3) or the “Compartment Patient” section of the standard adopted at § 170.215(a)(1) (HL7[®] FHIR[®] Release 4.0.1) as either patient/[Resource] or user/[Resource]. These resources include “Device,” “Location,” “Medication,” “Organization,” “Practitioner,” and “PractitionerRole.” Health IT developers must document their supported scopes according to the technical documentation requirements at § 170.315(g)(10)(viii)(A) and § 170.404(a)(2).

Applies to SVAP approved standards USCDI v4 and US Core 7.0.0:

- For demonstration of the SMART IG “Standalone Launch” steps, health IT developers are permitted to scope US Core IG resources that do not exist in either USCDI v4 or the “Compartment Patient” section of the standard adopted at § 170.215(a)(1) (HL7[®] FHIR[®] Release 4.0.1) as either patient/[Resource] or user/[Resource]. These resources include “Device,” “Medication,” “Organization,” “Practitioner,” and

“PractitionerRole.” Health IT developers must document their supported scopes according to the technical documentation requirements at § 170.315(g)(10)(viii)(A) and § 170.404(a)(2).

Applies to SVAP approved standards USCDI v5 and US Core 8.0.1:

- For demonstration of the SMART IG “Standalone Launch” steps, health IT developers are permitted to scope US Core IG resources that do not exist in either USCDI v5 or the “Compartment Patient” section of the standard adopted at § 170.215(a)(1) (HL7® FHIR® Release 4.0.1) as either patient/[Resource] or user/[Resource]. These resources include “Device,” “Medication,” “Organization,” “Practitioner,” and “PractitionerRole.” Health IT developers must document their supported scopes according to the technical documentation requirements at § 170.315(g)(10)(viii)(A) and § 170.404(a)(2).

Technical outcome - (A) Establish a secure and trusted connection with an application that requests data for patient and user scopes in accordance with the implementation specifications adopted in § 170.215(b)(1) and (c). (B) Establish a secure and trusted connection with an application that requests data for system scopes in accordance with an implementation specification adopted in § 170.215(d).

Applies to all applicable base regulatory and SVAP standards:

- TLS version 1.2 or above must be enforced for the appropriate connections.
- Health IT developers are encouraged but not required to follow [TLS Best Current Practice \(BCP 195\)](#) for TLS version enforcement, referenced in [section 6.1.0.3 of the HL7 4.0.1 Fast Healthcare Interoperability Resources Specification \(FHIR\) Release 4, October 30, 2019](#), which recommends TLS 1.2 or above to be used for all production data exchange and limits support for lower versions of TLS. To meet ONC Certification requirements, Health IT developers must document how the Health IT Module enforces TLS version 1.2 or above to meet the API documentation requirements at § 170.315(g)(10)(viii) and API Transparency Conditions at 45 CFR 170.404(a)(2).

Technical outcome – For first time connections, authentication and authorization must occur during the process of granting access to patient data in accordance with an implementation specification adopted in § 170.215(c) and standard adopted in § 170.215(e)(1). Additionally, a Health IT Module’s authorization server must issue a refresh token valid for a period of no less than three months to applications using the “confidential app” profile according to an implementation specification adopted in § 170.215(c). Finally, a Health IT Module’s authorization server must issue a refresh token for a period of no less than three months to native applications capable of securing a refresh token.

Applies to all applicable base regulatory and SVAP standards:

- Health IT Modules will be explicitly tested for US Core IG operations using authentication and authorization tokens acquired via the process described in an implementation specification adopted in § 170.215(c).
- Only the relevant parts of the OpenID Connect Core 1.0 including errata set 1 adopted in § 170.215(e)(1) that are also included in an implementation specification adopted in § 170.215(c) will be in-scope for testing and certification.
- Although Health IT Modules presented for testing and certification must include the ability for patients to authorize an application to receive their EHI based on FHIR® resource-level scopes, Health IT Modules are not prohibited from presenting authorization scopes in a more user-friendly format (e.g. grouping resources under categories, renaming the scopes for easier comprehension by the end-user, using more granular scopes), as long as the ability for patients to authorize applications based on resource-level scopes is available, if requested by the patient.
- For § 170.315(g)(10) criterion requirements at § 170.315(g)(10)(v)(A) regarding authorization for patient and user scopes, we clarify wildcard scopes as defined in the implementation specifications at § 170.215(c) are not required to be supported.
- Health IT Modules will only be tested for the "Patient Access for Standalone Apps" and "Clinician Access for EHR Launch" "Capability Sets" described in an implementation specification adopted at § 170.215(c).
- Since the “Patient Access for Standalone Apps” and “Clinician Access for EHR Launch” “Capability Sets” do not include “context-standalone-encounter” ONC will not test Health IT Modules for support for the "context-standalone-encounter" SMART on FHIR® Capability described in an implementation specification adopted at § 170.215(c).
- Implementers of § 170.315(g)(10)-certified Health IT Modules should be mindful of the information blocking provisions.
- As part of the requirements at § 170.315(g)(10)(v)(A)(1)(iii), health IT developers must publish the method(s) by which their Health IT Modules support the secure issuance of an initial refresh token to native applications according to the technical documentation requirements at § 170.315(g)(10)(viii) and transparency conditions at § 170.404(a)(2).
- Application developer affirmations to health IT developers regarding the ability of their applications to secure a refresh token, a client secret, or both, must be treated in a good faith manner consistent

with the provisions established in the openness and pro-competitive conditions at § 170.404(a)(4).

- Health IT developers can determine the method(s) they use to support interactions with native applications and clarify that health IT developers are not required to support all methods third-party application developers seek to use.
- ONC recognizes there may be some ambiguity in the HL7[®] SMART Application Launch Framework Implementation Guide (incorporated by reference at § 170.215(c)) in its guidance for supporting native applications, in particular, in providing references to best practices, strategies, and examples such as “OAuth 2.0 for Native Apps: 8.5. Client Authentication”, “OAuth 2.0 Dynamic Client Registration Protocol”, and “universal redirect_uris” without a standardized solution. ONC provides flexibility for how the health IT developer implements the HL7[®] SMART Application Launch Framework implementation specification, as long as the Certified Health IT Module supports for first time connections the issuance of three-month refresh tokens to native applications capable of securing a refresh token.
- The paragraph at § 170.215(c) requires health IT developers to support the SMART Application Launch Framework Implementation Guide (SMART IG) “SMART [on FHIR[®]] Core Capabilities,” including “permission-offline,” which grants support for refresh tokens. The implementation specifications adopted in § 170.215(c) require that patients have the ability to explicitly enable the “offline_access” scope during authorization. If the “offline_access” scope is not enabled by patients, patients will be required to re-authenticate and re-authorize an application's access to their EHI after the application's access token expires. However, the ability of a patient to explicitly enable the “offline_access” scope during authorization is not described in the implementation specification. ONC clarifies that health IT developers must support the ability for patients to be provided information about an application's request for persistent access prior to the patient sharing their health information, in order to enable patients to make an informed decision during authorization. Examples include, but are not limited to a health IT developer allowing patients to granularly grant “offline-access” scopes during authorization or clearly providing this information as a notice during authorization. The critical requirement is that patients are empowered to deny authorization for offline access.
- The SMART capabilities in § 170.215(c) are explicitly required for testing and certification because these capabilities are otherwise indicated as optional in the implementation specification.

Applies to SMART App Launch 2.0.0 and SVAP approved standard SMART App Launch 2.2.0:

- For certification purposes, a Health IT Module is not required to support authorization requests nor responses including a combination of SMART v1 and SMART v2 scopes. For example, an authorization request including simultaneously the SMART v1 scope of “patient/Observation.read” and the SMART v2 scope of “patient/Condition.rs” is not required to be supported.
- A Health IT Module may optionally support the "fhirContext" launch context parameter defined in the SMART App Launch 2.0.0 implementation guide. If the "fhirContext" parameter is supported, the Health IT Module must conform to the requirements for the parameter detailed in the SMART App Launch implementation guide.
- We clarify the following SMART App Launch capabilities must be supported as part of fulfilling the authentication and authorization requirements at § 170.315(g)(10)(v)(A) when certifying using the implementation specification at § 170.215(c)(2):
 - To support patient access for standalone apps, the Health IT Module must support:
 - the capabilities of "launch-standalone" and "context-standalone-patient"; and

- the capabilities in subsections "Authorization Methods", "Client Types", "Single Sign-on", and "Permissions" except the "permission-online" and "permission-user" capabilities
- To support clinician access for EHR launch, the Health IT Module must support:
 - the capabilities of "launch-ehr", "context-banner", "context-style", "context-ehr-patient", and "context-ehr-encounter" (if supporting USCDI v2 or v3); and
 - the capabilities in subsections "Authorization Methods", "Client Types", "Single Sign-on", and "Permissions" except the "permission-online" capability
- As finalized in the HTI-1 Final Rule ([89 FR 1294](#)), Health IT Modules are required to support SMART App Launch "Finer-grained resource constraints using search parameters" for the "category" parameter for the Condition resource with Condition sub-resources Encounter Diagnosis, Problem List, and Health Concern, and the Observation resource with Observation sub-resources Clinical Test, Laboratory, Social History, SDOH, Survey, and Vital Signs. We defer to the implementation guides referenced at § 170.215(b)(1) and § 170.215(c) for specific implementation guidance for this requirement. In the context of the US Core 6.1.0 implementation guide, the Observation sub-resources of Clinical Test and SDOH may have scopes supported as follows:
 - support for scopes for the Observation sub-resource Clinical Test using the "procedure" code from the [US Core Clinical Result Observation Category value set](#).
 - support for scopes for the Observation sub-resource SDOH using the "sdoh" code from the [US Core Category code system](#).
- The US Core 7.0.0 IG and 8.0.1 IGs include requirements for how scopes for the Condition and Observation resources must be supported, including requirements in the ["SMART on FHIR Obligations and Capabilities" section](#) as well as Condition and Observation profiles sections.
- For certification and testing purposes the Health IT Module must demonstrate support for patients and users to authorize an app to receive patient data using scopes with "Finer-grained resource constraints using search parameters" for the sub-resources specified in the HTI-1 Final Rule. We require a Health IT Module to support a patient's ability to provide authorization at the individual sub-resource scope level.
- Although Health IT Modules presented for testing and certification must include the ability for patients to authorize an application to receive their EHI based on individual FHIR resource level and individual sub-resource level scopes, Health IT Modules are not prohibited from presenting authorization scopes in a more user-friendly format (e.g. grouping scopes under categories, renaming the scopes for easier comprehension by the end-user), as long as the ability for patients to authorize applications based on individual resource level and individual sub-resource level scopes is available, if requested by the patient.
- As part of supporting the SMART App Launch "permission-v2" capability for the purposes of certification, if an app requests authorization for a resource level scope for the "Condition" or "Observation" resources, then for patient authorization purposes a Health IT Module must support presentation of the required sub-resource scopes to the patient for authorization. Specifically, sub-resource scopes must be presented for patient authorization as follows:
 - "Condition" sub-resource scopes "Encounter Diagnosis", "Problem List", and "Health Concern" if a "Condition" resource level scope is requested
 - "Observation" sub-resource scopes "Clinical Test", "Laboratory", "Social History", "SDOH", "Survey", and "Vital Signs" if an "Observation" resource level scope is requested

- For purposes of certification to the § 170.315(g)(10) criterion, a Health IT Module is not required to support for authorization purposes presentation of sub-resource scopes to the user during clinician access for EHR launch.

Technical outcome – For subsequent connections, access must be granted to patient data in accordance with an implementation specification adopted in § 170.215(c) without requiring re-authorization and re-authentication when a valid refresh token is supplied by the application. Additionally, a Health IT Module’s authorization server must issue a refresh token valid for a new period of no less than three months to applications using the “confidential app” profile according to an implementation specification adopted in § 170.215(c).

Applies to all applicable base regulatory and SVAP standards:

- For subsequent connections of applications capable of storing a client secret, Health IT Modules are required to issue a refresh token valid for a new period of no shorter than three months per the API certification criterion requirement finalized in § 170.315(g)(10)(v)(A)(2)(ii).

Technical outcome – Authentication and authorization must occur during the process of granting an application access to patient data in accordance with the “SMART Backend Services: Authorization Guide” section of an implementation specification adopted in § 170.215(d) and the application must be issued a valid access token.

Applies to all applicable base regulatory and SVAP standards:

- Health IT Modules may use access control schemes other than OAuth 2.0 for controlling access to the file server, such as capability URLs. The HL7[®] FHIR[®]-I Work Group has documented expectations for the use of capability URLs with the Bulk Data Access IG on the [HL7[®] confluence website](#). For purposes of Certification testing, Health IT Modules will be tested for the ability to share bulk data files either using OAuth 2.0 bearer tokens or via capability URLs accessible without preconditions or additional steps.

Technical outcome – A Health IT Module’s authorization server must be able to revoke and must revoke an authorized application’s access at a patient’s direction within one hour of the request.

Applies to all applicable base regulatory and SVAP standards:

- This is a functional requirement to allow health IT developers the ability to implement it in a way that best suits their existing infrastructure and allows for innovative models for authorization revocation to develop.
- Patients are expected to have the ability to revoke an authorized application's access to their EHI at any time.
- For authorization revocation, Health IT Modules presented for certification are permitted to allow short-lived access tokens to expire in lieu of immediate access token revocation. ONC recommends health IT developers limit the lifetime of access tokens to one hour or less as recommended in the implementation specifications adopted at § 170.215(c). For purposes of testing and certification, Health IT Modules will be tested for patient authorization revocation occurring within one hour of the request.

Technical outcome – A Health IT Module's authorization server must be able to receive and validate tokens it has issued in accordance with an implementation specification in § 170.215(c).

Applies to all applicable base regulatory and SVAP standards:

- Health IT Developers must support token introspection as defined in a version of the SMART App Launch implementation specification adopted in § 170.215(c).

Technical outcome – The API(s) must include complete accompanying documentation that contains, at a minimum: (1) API syntax, function names, required and optional parameters supported and their data types, return variables and their types/structures, exceptions and exception handling methods and their returns; (2) The software components and configurations that would be necessary for an application to implement in order to be able to successfully interact with the API and process its response(s); and (3) All applicable technical requirements and attributes necessary for an application to be registered with a Health IT Module's authorization server.

Applies to all applicable base regulatory and SVAP standards:

- Health IT developers are not required to re-publish documentation from the adopted standards and implementation specifications. However, health IT developers must publish documentation that goes beyond the adopted standards and implementation specifications.
- Health IT developers are expected to disclose any additional data their § 170.315(g)(10)-certified Health IT Module supports in the context of the adopted standards and implementation specifications.

Technical outcome – The documentation used to meet paragraph (g)(10)(viii)(A) of this section must be available via a publicly accessible hyperlink without any preconditions or additional steps.

Applies to all applicable base regulatory and SVAP standards:

- No additional clarifications.

Regulation Text

§ 170.315(g)(10) Standardized API for patient and population services

The following technical outcomes and conditions must be met through the demonstration of application programming interface technology.

(i) Data response.

- (A) Respond to requests for a single patient's data according to the standard adopted in § 170.215(a)(1) and implementation specifications adopted in § 170.215(a) and in § 170.215(b)(1), including the mandatory capabilities described in "US Core Server CapabilityStatement," for each of the data included in the standards adopted in § 170.213. All data elements indicated as "mandatory" and "must support" by the standards and implementation specifications must be supported.
- (B) Respond to requests for multiple patients' data as a group according to the standards and implementation specifications adopted in § 170.215(a), (b)(1), and (d), for each of the data included in the standards adopted in § 170.213. All data elements indicated

as “mandatory” and “must support” by the standards and implementation specifications must be supported.

(ii) Supported search operations.

- (A) Respond to search requests for a single patient’s data consistent with the search criteria included in the implementation specifications adopted in § 170.215(b)(1), specifically the mandatory capabilities described in “US Core Server CapabilityStatement.”
- (B) Respond to search requests for multiple patients' data consistent with the search criteria included in the implementation specification adopted in § 170.215(d).

(iii) Application registration.

Enable an application to register with the Health IT Module’s “authorization server.”

(iv) Secure connection.

- (A) Establish a secure and trusted connection with an application that requests data for patient and user scopes in accordance with the implementation specifications adopted in § 170.215(b)(1) and (c).
- (B) Establish a secure and trusted connection with an application that requests data for system scopes in accordance with the implementation specification adopted in § 170.215(d).

(v) Authentication and authorization.

(A) *Authentication and authorization for patient and user scopes*

(1) *First time connections.*

- (i) Authentication and authorization must occur during the process of granting access to patient data in accordance with the implementation specification adopted in § 170.215(c) and standard adopted in § 170.215(e).
- (ii) A Health IT Module’s authorization server must issue a refresh token valid for a period of no less than three months to applications using the “confidential app” profile according to an implementation specification adopted in § 170.215(c).
- (iii) A Health IT Module’s authorization server must issue a refresh token for a period of no less than three months to native

applications capable of securing a refresh token.

(2) *Subsequent connections.*

- (i) Access must be granted to patient data in accordance with the implementation specification adopted in § 170.215(c) without requiring re-authorization and re-authentication when a valid refresh token is supplied by the application.
- (ii) A Health IT Module's authorization server must issue a refresh token valid for a new period of no less than three months to applications using the "confidential app" profile according to an implementation specification adopted in § 170.215(c).

(B) *Authentication and authorization for system scopes.* Authentication and authorization must occur during the process of granting an application access to patient data in accordance with the "SMART Backend Services: Authorization Guide" section of the implementation specification adopted in § 170.215(d) and the application must be issued a valid access token.

(vi) Patient authorization revocation.

A Health IT Module's authorization server must be able to revoke and must revoke an authorized application's access at a patient's direction within 1 hour of the request.

(vii) Token introspection.

A Health IT Module's authorization server must be able to receive and validate tokens it has issued in accordance with an implementation specification in § 170.215(c).

(viii) Documentation.

(A) The API(s) must include complete accompanying documentation that contains, at a minimum:

- (1) API syntax, function names, required and optional parameters supported and their data types, return variables and their types/structures, exceptions and exception handling methods and their returns.
- (2) The software components and configurations that would be necessary for an application to implement in order to be able to successfully interact with the API and process its response(s).
- (3) All applicable technical requirements and attributes necessary for an application to be registered with a Health IT Module's authorization server.

- (B) The documentation used to meet paragraph (g)(10)(viii)(A) of this section must be available via a publicly accessible hyperlink without any preconditions or additional steps.

Standards & References

The following standards are referenced within the certification criteria for:

§ 170.215(a)(1)

[HL7® Fast Healthcare Interoperability Resources \(FHIR®\) Release 4.0.1](#) 

Referenced in the Following:

- Paragraph (g)(10)(i)(A)
- Paragraph (g)(10)(i)(B)

§ 170.213(b)

[United States Core Data for Interoperability Version 3 \(USCDI v3\)](#) 

Referenced in the Following:

- Paragraph (g)(10)(i)(A)
 - Paragraph (g)(10)(i)(B)
-

SVAP-approved Versions:

[United States Core Data for Interoperability \(USCDI\), Version 5](#) 

§ 170.215(d)(1)

[FHIR® Bulk Data Access \(Flat FHIR®\) \(v1.0.0: STU 1\), including mandatory support for the “group-export” “OperationDefinition”](#)

Referenced in the Following:

- Paragraph (g)(10)(i)(B)
 - Paragraph (g)(10)(ii)(B)
 - Paragraph (g)(10)(iv)(B)
 - Paragraph (g)(10)(v)(B)
-

SVAP-approved Versions:

[HL7® FHIR® Bulk Data Access \(Flat FHIR®\) \(v2.0.0: STU 2\)](#) 

§ 170.215(c)(2)

[HL7® SMART App Launch Implementation Guide Release 2.0.0, including mandatory support for the “Capability Sets” of “Patient Access for Standalone Apps” and “Clinician Access for EHR Launch”; all “Capabilities” as defined in “8.1.2 Capabilities,” excepting the “permission-online” capability; “Token Introspection” as defined in “7 Token Introspection”](#) 

Referenced in the Following:

- Paragraph (g)(10)(iv)(A)
- Paragraph (g)(10)(v)(A)(1)
- Paragraph (g)(10)(v)(A)(2)

§ 170.215(e)(1)

[OpenID Connect Core 1.0, incorporating errata set 1](#) 

Referenced in the Following:

- Paragraph (g)(10)(v)(A)(1)

§ 170.215(b)(1)(ii)

[HL7® FHIR® US Core Implementation Guide STU 6.1.0](#) [↗](#)

Referenced in the Following:

- Paragraph (g)(10)(i)(A)
 - Paragraph (g)(10)(i)(B)
 - Paragraph (g)(10)(iv)(A)
 - Paragraph (g)(10)(ii)(A)
-

SVAP-approved Versions:

[HL7® FHIR® US Core Implementation Guide STU 7.0.0, May 2024](#) [↗](#)

[HL7 FHIR® US Core Implementation Guide STU 8.0.1](#) [↗](#)

Certification Dependencies

§ 170.404

Application Programming Interfaces (API)

Products certified to this criterion have specific requirements related to the certification of API Modules

§ 170.405

Real World Testing

Products certified to this criterion must complete requirements outlined for the Real World Testing Conditions and Maintenance of Certification.

Note: Enforcement discretion has been issued for CY 2025–2026. Refer to the [Enforcement Discretion Notices](#) for full details.

Insights

Products certified to this criterion must submit responses for the following measures:

- Individuals' access to electronic health information through certified health IT
- Applications supported through certified health IT
- Use of FHIR in apps through certified health IT
- Use of FHIR bulk data access through certified health IT

Privacy and Security

This certification criterion was adopted in § 170.315(g)(10). As a result, an ONC Authorized Certification Body (ONC-ACB) must ensure that a product presented for certification to this criterion includes the privacy and security criteria (adopted in § 170.315(d)) within the overall scope of the certificate issued to the product.

- The privacy and security criteria (adopted in § 170.315(d)) do not need to be explicitly tested with this specific criterion unless it is the only criterion for which certification is requested.
- As a general rule, a product presented for certification only needs to be tested once to each applicable privacy and security criterion (adopted in § 170.315(d)) so long as the health IT developer attests that such privacy and security capabilities apply to the full scope of capabilities included in the requested certification.

For more information on the approaches to meet these Privacy and Security requirements, please download the Privacy and Security CCG below:

Approaches:

if choosing

Approach 1

- [Authentication, access control, and authorization \(§ 170.315\(d\)\(1\)\)](#).
- [Trusted connection \(§ 170.315\(d\)\(9\)\)](#).
- Either [Auditable events and tamper-resistance \(§ 170.315\(d\)\(2\)\)](#) or [Auditing actions on health information \(§ 170.315\(d\)\(10\)\)](#).
 - Note: If a developer elects to demonstrate §170.315(d)(2), they only need to demonstrate § 170.315(d)(2)(i)(A) – (B) and § 170.315(d)(2)(ii) – (v) for the privacy and security requirements for this criterion.
- [Encrypt authentication credentials \(§ 170.315\(d\)\(12\)\)](#).
- [Multi-factor authentication \(MFA\) \(§ 170.315\(d\)\(13\)\)](#).

if choosing

Approach 2

For each applicable privacy and security certification criterion not certified for Approach 1, the health IT developer may certify using system documentation that is sufficiently detailed to enable integration such that the Health IT Module has implemented service interfaces for each applicable privacy and security certification criterion that enable the Health IT Module to access external services necessary to meet the requirements of the privacy and security certification criterion. Please see the *21st Century Cures Act: Interoperability, Information Blocking, and the ONC Health IT Certification Program Final Rule* at [85 FR 25710](#) for additional clarification.

170.550(h)

Design and Performance

The following design and performance certification criteria (adopted in § 170.315(g)) must also be certified in order for the product to be certified.

- [Quality management system \(§ 170.315\(g\)\(4\)\)](#): When a single quality management system (QMS) is used, the QMS only needs to be identified once. Otherwise, when different QMS are used, each QMS needs to be separately identified for every capability to which it was applied.
- [Accessibility-centered design \(§ 170.315\(g\)\(5\)\)](#): When a single accessibility-centered design standard is used, the standard only needs to be identified once. Otherwise, the accessibility-centered design standards need to be identified for every capability to which they were applied; or, alternatively, the developer must state that no accessibility-centered design was used.

Certification Companion Guide Changelog

The following changelog applies to:

§ 170.315(g)(10) Standardized API for patient and population services

Revision History

Version

1.0

Description of Change

Initial publication

Version Date

03-11-2024

Version

1.1

Description of Change

- Clarified in the “Required Update Deadlines” that the new patient access revocation requirements introduced in HTI-1 Final Rule for paragraph (g)(10)(vi) are required by March 11, 2024.

- Revised clarification for paragraph (g)(10)(i)(A) for US Core 6.1.0 and USCDI v3 to indicate that for the “Practitioner” US Core IG profile only the “read” type interaction must be supported.

Version Date

05-16-2024

Version #

1.2

Description of Change

Updated a typo in 170.215(d)(1) standard referenced to reflect the correct version cited in regulation as V1.0.0.

Version Date

07-22-2024

Version #

1.3

Description of Change

- For Paragraph (g)(10)(i)(A), added a clarification in alignment with US Core ‘Patch’ Process ticket FHIR-45319.
- For Paragraph (g)(10)(v)(A)(1), added new clarification regarding support for authorization requests simultaneously including both SMART v1 and SMART v2 scopes, and revised and added clarifications regarding support for granular SMART v2 scopes defined using “Finer-grained resource constraints using search parameters”.

Version Date

08-05-2024

Version #

1.4

Description of Change

Standards Referenced updated to reflect the 2024 Approved SVAP Standards.

Version Date

08-19-2024

Version #

1.5

Description of Change

- Applicable to the entire criterion: Added clarifications regarding US Core “patches” and “additional guidance” approved by the HL7 Cross-Group Projects Work Group.
- For Paragraph (g)(10)(i)(A), added clarifications for US Core “patches” FHIR-43355 and FHIR-44693.

Version Date

08-30-2024

Version #

1.6

Description of Change

For Paragraph (g)(10)(i)(A), added clarification for US Core “patch”

[FHIR-46240](#)

.

Version Date

11-05-2024

Version #

1.7

Description of Change

Updated clarifications for SVAP 2024 adopted standards.

Version Date

11-13-2024

Version #

1.8

Description of Change

- Updated link for § 170.215(c)(2) HL7® SMART App Launch Implementation Guide Release 2.0.0 under Standard(s) Referenced
- For entire criterion, added clarification regarding compliance with EO 14168 and OPM guidance

Version Date

03-27-2025

Version

1.9

Description of Change

For Paragraph (g)(10)(i)(A), added clarifications for US Core “patches” FHIR-50283, FHIR-50239, and FHIR-50288.

Version Date

06-06-2025

Version

1.10

Description of Change

Added update to Certification Dependencies section to reflect recent Real World Testing enforcement discretion notice.

Version Date

07-23-2025

Version

1.11

Description of Change

Updated standards referenced and clarifications for SVAP 2025 adopted standards.

Version Date

08-29-2025

Version

1.12

Description of Change

- Removed references and clarifications for expired standards USCDI v1, US Core v3.1.1, US Core v4.0.0, and SMART App Launch v1.0.0.
- Adopted HL7® FHIR® US Core Implementation Guide STU 8.0.1 as errata for [HL7® FHIR® US Core Implementation Guide STU 8.0.0](#).
- Added clarification indicating “QuestionnaireResponse” US Core IG profile is not required to be supported for US Core 8.0.1

Version Date

05-15-2026

